

ClientOpsCRM 2.0.0 Security and Adversarial Review

Threat model

The standalone CRM is a local compiled process operating on an operator-selected SQLite database. Primary threats are malformed/untrusted imported data, SQL injection, duplicate/ambiguous identity, illegal state transitions, partial multi-record writes, accidental schema mismatch, tampering with mutation evidence, corrupt relational references, unsafe file permissions through the integrated launcher, and automation that mistakes formatted output for success.

The Relay network/deployment threat model remains covered by the inherited Relay security documentation and tests. The CRM does not open a listening socket.

Controls implemented

SQL/data separation

All data-bearing database operations use prepared SQLite statements and bound parameters. Dynamic choice of export entity is allow-listed to fixed SQL strings. This follows the same central defense recommended by OWASP SQL Injection Prevention: separate query structure from untrusted values.

Syntactic and semantic validation

Inputs are bounded and parsed before persistence. Email has deterministic structural checks; dates validate calendar month/day/leap-year rules; amount parsing accepts exact decimal syntax and at most two fractional digits; priorities/status/entity types are allow-listed; metadata must pass SQLite JSON validity; custom keys use restricted identifier syntax. Database CHECK constraints repeat critical ranges and enumerations.

Transactional conversion

Lead conversion is the highest-risk compound mutation. It uses `BEGIN IMMEDIATE` and an RAIL rollback guard. A failure after any intermediate step rolls back the transaction. The adversarial suite repeats conversion on an already-converted lead and compares account/contact/deal counts before and after to prove no partial side effect survives.

State-machine defense in depth

Application handlers enforce legal lifecycle transitions. Database triggers independently enforce that a deal's selected stage belongs to its selected pipeline and that the stage kind equals the deal status. A direct SQL adversary attempting to insert an open deal into the won stage receives a database error.

Audit tamper resistance

Audit rows are generated by database triggers with the actor stored in a one-row connection context. `BEFORE UPDATE` and `BEFORE DELETE` triggers on `audit_log` abort all mutation/deletion. The adversarial test bypasses the CLI, opens SQLite directly, and verifies both tamper attempts fail.

This is append-only protection within the application database boundary, not cryptographic immutability against an administrator who replaces or edits the database file offline. Release

integrity hashes protect distributed artifacts, while host/storage controls remain necessary for operational evidence custody.

Identity and duplicate handling

Normalized non-empty account domains and contact emails are unique. Relay ticket identity is unique. Phone normalization is intentionally not unique because shared numbers are legitimate; dedupe reports clusters for operator review. This distinguishes hard identity invariants from heuristic duplicate signals.

Schema safety

`crm_meta.schema_version` must match `2.0.0`. `init` refuses a database declaring another version rather than rewriting it. This prevents accidental downgrade/open-by-wrong-version behavior.

Database health

`doctor` executes SQLite integrity and foreign-key checks and verifies higher-level invariants that SQLite cannot express with ordinary foreign keys because tasks/notes/custom values use controlled polymorphic references.

File permissions

When the top-level launcher creates its default CRM state, it creates the runtime directory mode `0700` and database mode `0600`. An explicit `--db` path is operator-controlled and inherits the host's path/umask policy.

Adversarial cases executed

The release test suite includes duplicate normalized identities, SQL-looking text in a normal lead message, double conversion, conversion rollback, illegal closed-deal movement, missing lost reason, double task completion, malformed custom key, direct stage/status mismatch insertion, audit UPDATE, audit DELETE, future schema refusal, complex CSV quoting/newlines, JSON meta-data round trip, import replay idempotency and deterministic repeated reads.

The same behavior suite is executed against the optimized binary and the ASan/UBSan build.

Relay bridge safety properties

The bridge invokes `docker compose exec -T postgres psql --no-psqlrc --set ON_ERROR_STOP=1`, reducing dependence on user `psql` configuration and making SQL failure fatal. PostgreSQL emits CSV; CRM parsing/validation remains authoritative on the receiving side. No temporary export file is required. Stable Relay UUIDs plus unique index plus `--skip-existing` provide replay safety.

Residual operational risks

Security controls cannot make an untrusted host trustworthy. An administrator who can replace the binary/database or alter the source before compilation can alter behavior. Backups can expose CRM data if stored without host-level access control. Business users can still enter factually wrong information that passes syntactic validation. Weighted forecasts reflect configured probabilities and are not calibrated predictions.

These are addressed operationally by release hashes, least-privilege storage, backups, audit review, doctor, explicit actor use, and human review of business semantics rather than by pretending software validation can prove real-world truth.